

báo cáo phishing

by THỊNH HOÀNG QUANG

Submission date: 29-Mar-2026 03:33PM (UTC+0700)

Submission ID: 2916095979

File name: 31741_TH_NH_HO_NG_QUANG_b_o_c_o_phishing_400_1934282810.docx (33.71K)

Word count: 5697

Character count: 21343

DANH MỤC CÁC KÝ HIỆU VÀ TỪ VIẾT TẮT

STT	TỪ VIẾT TẮT	TIẾNG ANH	TIẾNG VIỆT
1	API	Application Programming Interface	Giao diện lập trình ứng dụng
2	APWG	Anti-Phishing Working Group	
3	AUC	Area Under the Curve	Diện tích dưới đường cong
4	CSS	Cascading Style Sheets	
5	DGA	Domain Generation Algorithm	Thuật toán sinh tên miền
6	DNS	Domain Name System	Hệ thống phân giải tên miền
7	DT	Decision Tree	Cây quyết định
8	FNR	False Negative Rate	Tỷ lệ bỏ sót
9	FPR	False Positive Rate	Tỷ lệ báo động giả
10	HTML	HyperText Markup Language	Ngôn ngữ đánh dấu siêu văn bản
11	HTTP	HyperText Transfer Protocol	Giao thức truyền tải siêu văn bản
12	HTTPS	HyperText Transfer Protocol Secure	Giao thức siêu văn bản bảo mật
13	JSON	JavaScript Object Notation	
14	LightGBM	Light Gradient Boosting Machine	
15	LR	Logistic Regression	Hồi quy logistic
16	MCC	Matthews Correlation Coefficient	Hệ số tương quan Matthews
17	ML	Machine Learning	Học máy
18	PCA	Principal Component Analysis	Phân tích thành phần chính
19	RF	Random Forest	Rừng ngẫu nhiên
20	ROC	Receiver Operating Characteristic	Đặc trưng vận hành bộ thu

STT	TỪ VIẾT TẮT	TIẾNG ANH	TIẾNG VIỆT
21	SMOTE	Synthetic Minority Over-Sampling Technique	Kỹ thuật tạo mẫu thiểu số tổng hợp
22	SOC	Security Operations Center	Trung tâm điều hành an ninh mạng
23	SSL	Secure Sockets Layer	Giao thức lớp ổ bảo mật
24	SVM	Support Vector Machine	Máy vector hỗ trợ
25	TLS	Transport Layer Security	Bảo mật lớp giao vận
26	URL	Uniform Resource Locator	Địa chỉ tài nguyên thống nhất
27	XGBoost	eXtreme Gradient Boosting	

CHƯƠNG 1. TỔNG QUAN

1.1. Giới thiệu đề tài

Trong bối cảnh chuyển đổi số diễn ra mạnh mẽ tại Việt Nam và toàn cầu, lừa đảo trực tuyến thông qua các URL giả mạo đã trở thành một trong những mối đe dọa an ninh mạng nghiêm trọng và phổ biến nhất hiện nay. Người dùng thường xuyên bị lừa truy cập vào các trang web giả mạo hệ thống ngân hàng thương mại, cổng email doanh nghiệp hoặc các dịch vụ hành chính trực tuyến, dẫn đến nguy cơ mất thông tin cá nhân và tài sản tài chính.

Theo báo cáo tình báo mối đe dọa của tổ chức IBM X-Force, lừa đảo trực tuyến hiện vẫn tiếp tục giữ vị trí vector tấn công hàng đầu được tin tặc sử dụng để xâm nhập vào hệ thống. Số lượng các cuộc tấn công phishing toàn cầu đã đạt mức kỷ lục 1.270.883 cuộc chỉ trong quý 3 năm 2022 và tiếp tục duy trì ở gần 1 triệu chiến dịch trong quý 1 năm 2023, gây thiệt hại kinh tế ước tính 16,6 tỷ USD theo báo cáo của FBI năm 2024.

Các giải pháp truyền thống dựa trên danh sách đen như Google Safe Browsing và PhishTank hiện đang tỏ ra bất lực trước các URL lừa đảo mới. Kẻ tấn công liên tục tạo ra các URL mới với tuổi thọ trung bình chỉ 15 đến 20 giờ, trong khi việc cập nhật danh sách đen mất từ vài giờ đến vài ngày, tạo ra khoảng thời gian phơi nhiễm nguy hiểm cho người dùng chưa được bảo vệ.

Vì vậy, đề tài này tập trung xây dựng một tiện ích mở rộng trên trình duyệt Chrome kết hợp danh sách đen, phương pháp heuristic và mô hình học máy để phát hiện URL lừa đảo theo thời gian thực trực tiếp trên trình duyệt, không yêu cầu người dùng có kiến thức chuyên sâu về an toàn thông tin.

1.2. Mục tiêu nghiên cứu

Đề tài hướng đến xây dựng một bộ dữ liệu huấn luyện cân bằng và đầy đủ hai lớp bằng cách kết hợp nguồn URL lừa đảo từ PhishTank và OpenPhish với nguồn URL hợp lệ từ Alexa Top 1 Million và Cisco Umbrella, đồng thời xử lý mất cân bằng dữ liệu bằng kỹ thuật SMOTE. Trên bộ dữ liệu đó, đề tài thực hiện đánh giá đối chuẩn toàn diện sáu thuật toán học máy gồm Logistic Regression, Decision Tree, SVM, Random Forest,

LightGBM và XGBoost, với mục tiêu đạt độ chính xác từ 80% trở lên, F1-Score từ 85% trở lên và tỷ lệ báo động giả không vượt quá 5%.

Từ kết quả so sánh đó, đề tài lựa chọn mô hình tốt nhất để tích hợp vào tiện ích mở rộng Chrome theo chuẩn Manifest V3, kết hợp cùng hai lớp phòng thủ còn lại để phát hiện URL lừa đảo theo thời gian thực với độ trễ suy luận dưới 200ms. Toàn bộ kết quả nghiên cứu được công bố kèm mã nguồn, báo cáo phân tích và video demo minh họa.

1.3. Đối tượng và phạm vi nghiên cứu

Đối tượng nghiên cứu của đề tài bao gồm ba nhóm chính:

1. URL lừa đảo và các đặc trưng ngữ vựng của chúng.
2. Các thuật toán học máy cho bài toán phân loại nhị phân URL an toàn và URL lừa đảo.
3. Kiến trúc tiện ích mở rộng Chrome theo chuẩn Manifest V3.

Phạm vi nghiên cứu được giới hạn trong ba khía cạnh sau:

1. Chỉ sử dụng đặc trưng ngữ vựng tĩnh trích xuất từ chuỗi URL, không phân tích nội dung trang HTML hay thực hiện yêu cầu mạng, nhằm đảm bảo an toàn và tốc độ xử lý.
2. Dữ liệu huấn luyện lấy từ các nguồn công khai gồm PhishTank, OpenPhish cho URL lừa đảo và Alexa Top 1 Million, Cisco Umbrella cho URL hợp lệ, kết hợp ISCX-URL2016 làm tập dữ liệu tham chiếu.
3. Hệ thống hướng đến triển khai trên trình duyệt Google Chrome, đóng gói dưới dạng file .crx theo chuẩn Manifest V3.

1.4. Ý nghĩa khoa học và thực tiễn

Về ý nghĩa khoa học, đề tài đóng góp vào cơ sở nghiên cứu về ứng dụng học máy trong an toàn thông tin thông qua việc đánh giá đối chuẩn toàn diện sáu thuật toán phân loại trên tập dữ liệu kết hợp sau xử lý SMOTE, đề xuất quy trình trích xuất và tối ưu hóa đặc trưng ngữ vựng URL kết hợp giảm chiều PCA phù hợp với môi trường triển khai nhẹ tại phía client, và đánh giá đa chiều qua các chỉ số Accuracy, F1-Score, ROC-AUC, MCC, FPR, FNR cùng độ trễ suy luận.

Về ý nghĩa thực tiễn, sản phẩm tiện ích mở rộng Chrome của đề tài hỗ trợ trực tiếp người dùng cá nhân và doanh nghiệp phát hiện và ngăn chặn các cuộc tấn công lừa đảo theo thời gian thực, giảm thiểu rủi ro đánh cắp thông tin và gian lận ngân hàng trực tuyến. Hệ thống được thiết kế nhẹ, không chiếm nhiều tài nguyên trình duyệt và có thể triển khai ngay cho người dùng phổ thông mà không cần cấu hình phức tạp.

1.5. Cấu trúc đồ án

Ngoài phần mở đầu và tài liệu tham khảo, đồ án được tổ chức thành bốn chương với nội dung cụ thể như sau.

Chương 1: Tổng quan. Trình bày bối cảnh nghiên cứu, tính cấp thiết của đề tài, mục tiêu, đối tượng, phạm vi nghiên cứu và cấu trúc tổng thể của đồ án.

Chương 2: Cơ sở lý thuyết. Trình bày các khái niệm và phương pháp giải quyết vấn đề bao gồm tổng quan về phishing URL, các phương pháp phát hiện, kỹ thuật trích xuất đặc trưng và giám chiểu, nguồn dữ liệu và quy trình xử lý mất cân bằng, các thuật toán học máy được sử dụng, chỉ số đánh giá hiệu suất và kiến trúc tiện ích mở rộng Chrome Manifest V3.

Chương 3: Kết quả thực nghiệm. Mô tả môi trường thực nghiệm, thiết kế hệ thống, kết quả huấn luyện và so sánh mô hình, cùng với demo hoạt động của tiện ích mở rộng.

Chương 4: Kết luận và kiến nghị. Tổng hợp các kết quả đạt được, đánh giá những hạn chế còn tồn tại và đề xuất hướng phát triển trong tương lai.

CHƯƠNG 2. CƠ SỞ LÝ THUYẾT

2.1. Tổng quan về Phishing URL

2.1.1. Khái niệm và phân loại

Phishing hay tấn công giả mạo là một hình thức tấn công mạng sử dụng kỹ thuật thao túng tâm lý và các thủ đoạn kỹ thuật để lừa gạt người dùng. Thay vì nhắm vào các lỗ hổng của hệ thống phần mềm, phishing khai thác trực tiếp điểm yếu của con người. Kẻ tấn công thường mạo danh các tổ chức uy tín như ngân hàng, công ty công nghệ hay cơ quan chính phủ để gửi đi các tin nhắn hoặc email chứa URL độc hại. Khi nạn nhân nhấp vào các URL này, họ bị điều hướng đến các trang web giả mạo nhằm đánh cắp thông tin nhạy cảm như thông tin đăng nhập, dữ liệu thẻ tín dụng, hoặc bị bí mật cài đặt mã độc vào thiết bị.

Các hình thức phishing ngày càng đa dạng và tinh vi, được phân loại chủ yếu dựa trên phương thức tiếp cận và mục tiêu tấn công:

1. Email Phishing là hình thức phổ biến nhất, trong đó kẻ tấn công gửi email chứa URL độc hại đến hàng loạt người dùng ngẫu nhiên.
2. Spear Phishing là dạng lừa đảo có mục tiêu, kẻ tấn công thu thập thông tin về một cá nhân hoặc tổ chức cụ thể để soạn email mạo danh mang tính cá nhân hóa cao.
3. Whaling là dạng nâng cấp của Spear Phishing, nhắm vào các nhân vật cấp cao như giám đốc điều hành để chiếm đoạt quyền truy cập sâu hơn vào hệ thống cốt lõi.
4. Smishing và Vishing là lừa đảo thông qua tin nhắn SMS chứa URL độc hại hoặc qua các cuộc gọi điện thoại giả mạo để ép buộc nạn nhân cung cấp thông tin.
5. Pharming là kỹ thuật đánh lừa hệ thống DNS khiến nạn nhân bị định tuyến đến trang web giả mạo ngay cả khi gõ đúng địa chỉ hợp lệ.
6. Clone Phishing là tấn công nhân bản, kẻ tấn công tạo bản sao y hệt email hợp pháp mà nạn nhân đã nhận nhưng thay thế các liên kết an toàn bằng URL độc hại.

2.1.2. Thực trạng và xu hướng

Trên bình diện toàn cầu, tình hình lừa đảo trực tuyến đang bùng nổ với tốc độ cấp số nhân. Theo Nhóm Công tác Chống Phishing (APWG), số lượng các cuộc tấn công liên tục phá vỡ kỷ lục lịch sử: từ mốc 180.000 trang web phishing độc nhất trong

quý 1 năm 2019, đã tăng vọt lên mức 1.270.883 cuộc tấn công chỉ trong quý 3 năm 2022, trong đó 23,2% nhắm vào lĩnh vực tài chính. Đến quý 4 năm 2023, hệ thống ghi nhận 989.123 cuộc tấn công với mục tiêu hàng đầu chuyển dịch sang nền tảng mạng xã hội chiếm 42,8%. Trong quý 1 năm 2025, đã có gần 1 triệu chiến dịch tấn công được triển khai.

Sự nguy hiểm của phishing còn thể hiện qua mức độ thiệt hại kinh tế khổng lồ. Theo báo cáo của FBI năm 2024, phishing là nguyên nhân chính đóng góp vào khoản thiệt hại 16,6 tỷ USD do gian lận mạng. Tội phạm mạng toàn cầu được dự báo sẽ gây thiệt hại lên tới 10,5 nghìn tỷ USD mỗi năm vào năm 2025. Đặc biệt, tỷ lệ các liên kết mạng xã hội trong email độc hại đã tăng 600% so với năm 2023.

Tại Việt Nam, lừa đảo trực tuyến được xếp vào nhóm rủi ro an ninh mạng ở mức độ cao nhất. Theo báo cáo IBM X-Force, phishing vẫn tiếp tục giữ vị trí vector tấn công hàng đầu. Phương thức phổ biến là lừa người dùng Việt Nam truy cập vào các website giả mạo hệ thống ngân hàng thương mại, cổng email doanh nghiệp hoặc các dịch vụ hành chính trực tuyến nhằm đánh cắp tài khoản và chiếm đoạt tài sản.

2.2. Các phương pháp phát hiện Phishing URL

2.2.1. Phương pháp danh sách đen

Phương pháp danh sách đen duy trì một cơ sở dữ liệu chứa các URL, tên miền hoặc địa chỉ IP đã được xác nhận là độc hại trong quá khứ. Khi người dùng truy cập một URL, hệ thống thực hiện truy vấn đối chiếu; nếu URL đó có mặt trong danh sách, quyền truy cập sẽ bị chặn và cảnh báo được phát ra. Google Safe Browsing là ví dụ điển hình của phương pháp này.

Ưu điểm của phương pháp này là tốc độ truy vấn cực kỳ nhanh, độ trễ thấp và rất dễ triển khai. Phương pháp mang lại tỷ lệ báo động giả cực thấp đối với các mối đe dọa đã biết.

Nhược điểm là mang tính bị động, không bao giờ có thể liệt kê đầy đủ mọi URL độc hại do lượng URL mới sinh ra mỗi ngày là quá lớn. Kẻ tấn công dễ dàng vượt qua bằng cách thay đổi một chi tiết nhỏ trong URL. Quan trọng hơn, các URL lừa đảo hoàn toàn mới chưa kịp cập nhật vào cơ sở dữ liệu sẽ không bị phát hiện. Nghiên cứu chỉ ra

rằng tuổi thọ trung bình của một trang web phishing chỉ từ 15 đến 20 giờ, trong khi việc phân phối bản cập nhật danh sách đen mất từ vài giờ đến vài ngày.

2.2.2. Phương pháp heuristic

Phương pháp heuristic phân tích các đặc trưng tĩnh, hành vi hoặc cấu trúc của URL và trang web như tuổi đời tên miền, tính hợp lệ của chứng chỉ SSL, số lượng ký tự đặc biệt, sự xuất hiện của biểu mẫu nhập liệu nhạy cảm để đánh giá mức độ rủi ro dựa trên các quy tắc được định nghĩa trước.

Ưu điểm là có khả năng phát hiện các cuộc tấn công mới miễn là trang web mang những dấu hiệu lừa đảo phổ biến đã được định nghĩa trong quy tắc. Nhược điểm là tỷ lệ báo động giả thường cao vì các trang web hợp lệ hoàn toàn có thể vô tình mang các đặc điểm bị nghi ngờ. Do bộ quy tắc mang tính tĩnh, kẻ tấn công dễ dàng qua mặt bằng các kỹ thuật gây nhiễu hoặc ẩn nội dung độc hại.

2.2.3. Phương pháp học máy

Học máy giải quyết triệt để những hạn chế của hai phương pháp trên bằng cách tự động hóa việc trích xuất và học hỏi từ hàng nghìn đặc trưng tĩnh vi của hàng triệu URL. Khác với hệ thống quy tắc tĩnh, học máy có khả năng nhận diện các ranh giới phi tuyến tính phức tạp và tìm ra các mẫu ẩn sâu trong dữ liệu, giúp phát hiện chính xác các URL lừa đảo mới chưa từng tồn tại trước đây.

Các thuật toán học máy tiên tiến, đặc biệt là nhóm mô hình tập hợp như Random Forest hay XGBoost, cho phép đạt độ chính xác vượt trội thường từ 95% đến hơn 99%, đồng thời giảm thiểu tối đa các báo động nhầm. Mô hình có thể duy trì tính linh hoạt, thích ứng với các kỹ thuật né tránh mới bằng cách liên tục huấn luyện lại trên dữ liệu cập nhật.

2.3. Đặc trưng ngữ vựng URL

2.3.1. Các đặc trưng quan trọng

Đặc trưng ngữ vựng là các thuộc tính văn bản tĩnh được trích xuất trực tiếp từ chuỗi URL mà không cần tải nội dung trang web hay thực thi mã lệnh, đảm bảo an toàn tuyệt đối và tốc độ xử lý nhanh theo thời gian thực. Các nhóm đặc trưng quan trọng nhất bao gồm:

1. Cấu trúc và độ dài URL: Kẻ tấn công thường sử dụng các URL rất dài để che giấu tên miền lừa đảo thực sự. Việc đo lường độ dài của toàn bộ chuỗi URL, độ dài tên miền và độ dài đường dẫn là những chỉ báo phân loại rất mạnh.
2. Sự hiện diện của địa chỉ IP: Các URL hợp lệ thường sử dụng tên miền. Việc một URL sử dụng trực tiếp địa chỉ IP thường là dấu hiệu rõ ràng của ý đồ độc hại nhằm che giấu nguồn gốc hoặc vượt qua các hệ thống đánh giá uy tín tên miền.
3. Số lượng tên miền phụ: URL lừa đảo thường tạo ra nhiều cấp độ tên miền phụ để đánh lừa người dùng. Số lượng dấu chấm và mức độ phức tạp của tên miền phụ càng cao thì rủi ro lừa đảo càng lớn.
4. Tần suất ký tự đặc biệt: Việc đếm số lượng các ký tự như @, ?, =, // vô cùng quan trọng. Kẻ tấn công sử dụng chúng để gây nhiễu, ví dụ trình duyệt bỏ qua toàn bộ phần nằm trước @ trong URL.
5. Từ khóa lừa đảo và giả mạo thương hiệu: Các URL độc hại thường chứa các từ khóa nhạy cảm như login, secure, verify, update, account hoặc chứa tên của các thương hiệu lớn nhằm tạo sự tin tưởng.
6. Tỷ lệ chữ số và chỉ số entropy: Các tên miền được tạo **tự động bằng thuật toán** thường chứa chuỗi **ký tự** ngẫu nhiên hoặc có tỷ lệ chữ số cao bất thường. Tính toán chỉ số entropy giúp mô hình nhận diện các chuỗi không có cấu trúc ngôn ngữ tự nhiên.

2.3.2. Kỹ thuật giảm chiều dữ liệu

Khi thu thập đặc trưng từ các nguồn dữ liệu lớn, số lượng cột đặc trưng có thể tăng lên rất cao. Việc giữ lại các đặc trưng dư thừa hoặc nhiều có thể gây ra hiện tượng học vẹt và làm tăng độ phức tạp tính toán. Đề tài sử dụng hai kỹ thuật giảm chiều chính.

Ma trận tương quan đánh giá mối quan hệ tuyến tính giữa các cặp đặc trưng. Nếu hai đặc trưng có **hệ số tương quan quá** cao, chúng mang nội dung thông tin gần như giống hệt nhau và ta có thể an toàn loại bỏ một trong hai, giúp giảm thiểu độ nhiễu và độ phức tạp.

Phân tích thành phần chính (PCA) biến đổi tập hợp các đặc trưng ban đầu thành một tập hợp các thành phần chính hoàn toàn không tương quan với nhau, đồng thời giữ lại được phương sai lớn nhất từ tập dữ liệu gốc. Trong thực tế, PCA có thể nén hiệu quả

một tập dữ liệu từ 50 thuộc tính xuống chỉ còn 18 thuộc tính cốt lõi mà không làm suy giảm đáng kể độ chính xác. Việc kết hợp hai kỹ thuật này giúp giảm lượng bộ nhớ sử dụng, tăng tốc độ hội tụ khi huấn luyện và giảm độ trễ khi dự đoán, đảm bảo hệ thống đủ nhẹ để tích hợp vào tiện ích mở rộng Chrome.

2.4. Dữ liệu và tiền xử lý

2.4.1. Nguồn dữ liệu

Bộ dữ liệu huấn luyện được xây dựng từ sự kết hợp của nhiều nguồn độc lập, bao gồm cả hai lớp phân loại là URL lừa đảo và URL hợp lệ.

Nguồn URL lừa đảo được kết hợp từ PhishTank và OpenPhish nhằm tối đa hóa độ bao phủ. PhishTank cung cấp dữ liệu được cộng đồng xác minh thủ công với độ tin cậy cao; OpenPhish cung cấp dữ liệu phát hiện tự động theo thời gian thực trong vòng 5 phút. Do mức độ trùng lặp giữa hai nguồn chỉ khoảng 12%, việc kết hợp cả hai giúp mở rộng tổng diện tích bao phủ lên gần 88%.

Nguồn URL hợp lệ sử dụng Alexa Top 1 Million là danh sách một triệu tên miền có lưu lượng truy cập cao nhất thế giới. Đây là tiêu chuẩn thực tế được sử dụng rộng rãi nhất trong cộng đồng nghiên cứu phát hiện phishing, đại diện cho thói quen duyệt web thực tế của người dùng. Ngoài ra, Cisco Umbrella Top 1M được sử dụng bổ sung để tăng tính đa dạng.

Ngoài dữ liệu tự thu thập, đề tài sử dụng thêm UCI Phishing Websites Dataset và ISCX-URL2016 làm tập dữ liệu tham chiếu để kiểm tra chéo và so sánh kết quả với các nghiên cứu trước.

2.4.2. Xử lý mất cân bằng dữ liệu

Trong thực tế, tỷ lệ URL độc hại chỉ chiếm từ 0,05% đến 5% tổng lưu lượng web. Nếu không xử lý, mô hình sẽ bị thiên kiến về lớp đa số, dẫn đến tỷ lệ bỏ sót URL lừa đảo rất cao. Đây là rủi ro bảo mật nghiêm trọng nhất cần tránh. Đề tài áp dụng kết hợp hai kỹ thuật xử lý:

1. Oversampling dữ liệu: SMOTE sinh ra các mẫu tổng hợp cho lớp thiểu số bằng cách nội suy giữa các điểm dữ liệu phishing hiện có, giúp cải thiện đáng kể Recall và F1-Score.

2. Ở cấp độ thuật toán: Sử dụng tham số `scale_pos_weight` trong XGBoost và `class_weight` trong Scikit-learn để gán trọng số phạt lớn hơn cho lỗi phân loại sai URL lừa đảo thành URL hợp lệ.

Tỷ lệ phân chia tập huấn luyện và kiểm thử là 80/20 kết hợp phân chia phân tầng nhằm đảm bảo tỷ lệ hai lớp đồng nhất trong cả tập huấn luyện lẫn tập kiểm thử, ngăn ngừa rò rỉ dữ liệu. Sử dụng kiểm định chéo 5 lần để đánh giá độ ổn định của mô hình.

2.5. Các thuật toán học máy

2.5.1. Logistic Regression

Logistic Regression được đưa vào như mô hình cơ sở nhằm cung cấp tiêu chuẩn so sánh tối thiểu để chứng minh sự cần thiết của các thuật toán phức tạp hơn. Nếu Random Forest, XGBoost hay LightGBM không mang lại độ chính xác vượt trội hơn Logistic Regression một cách đáng kể, thì Logistic Regression sẽ là lựa chọn tối ưu về chi phí tính toán.

Nguyên lý hoạt động: Logistic Regression là mô hình tuyến tính ánh xạ tổ hợp tuyến tính các đặc trưng URL sang xác suất thuộc lớp phishing qua hàm sigmoid. Ưu điểm nổi bật là khả năng diễn giải cao, tốc độ suy luận cực nhanh và xác suất đầu ra được hiệu chuẩn tốt giúp tinh chỉnh ngưỡng cảnh báo linh hoạt. Nhược điểm là giả định quan hệ tuyến tính giữa đặc trưng và nhãn, không nắm bắt được các tương tác phi tuyến phức tạp vốn phổ biến trong URL lừa đảo.

2.5.2. Random Forest

Random Forest là thuật toán học tập hợp hoạt động dựa trên kỹ thuật Bagging. Thuật toán này tạo ra nhiều tập dữ liệu con từ tập dữ liệu huấn luyện ban đầu bằng cách lấy mẫu ngẫu nhiên có thay thế.

Cấu trúc: Mô hình xây dựng một rừng gồm nhiều cây quyết định hoàn toàn độc lập và song song. Tại mỗi nút phân chia, Random Forest chỉ chọn ngẫu nhiên một tập con đặc trưng để tìm điểm chia cắt tối ưu. Kết quả dự đoán cuối cùng được tổng hợp bằng bỏ phiếu đa số từ tất cả các cây. Ưu điểm nổi bật là khả năng chống học vẹt rất tốt, ít nhạy cảm với nhiễu và cung cấp mức độ quan trọng của từng đặc trưng một cách trực quan. Trong bài toán phân loại phishing URL, Random Forest đạt độ chính xác từ 89,7% đến 97,6% với F1-Score từ 96,2% đến 97,2%.

2.5.3. XGBoost

XGBoost hoạt động dựa trên cơ chế Boosting, xây dựng các cây quyết định tuần tự trong đó mỗi cây tối ưu hóa hàm mất mát bằng Gradient Descent để sửa chữa lỗi của các cây trước. XGBoost vượt trội nhờ tích hợp sẵn điều chỉnh L1 và L2 ngăn học vẹt, thuật toán xử lý dữ liệu thiếu và hỗ trợ tính toán song song. Thuật toán đạt độ chính xác từ 94,2% đến 99,8% với tỷ lệ báo động giả thấp nhất là 2,3%.

Triển khai trong đề tài: Sau khi huấn luyện offline bằng Python, toàn bộ cấu trúc cây quyết định được xuất sang file JSON. Tiện ích mở rộng Chrome dùng JavaScript thuần đọc JSON và suy luận bằng logic IF-ELSE phía client, không cần thư viện học máy nặng và đảm bảo độ trễ dưới 200ms.

2.5.4. LightGBM

LightGBM là thuật toán Gradient Boosting được Microsoft phát triển với hai cải tiến kiến trúc cốt lõi so với XGBoost. Thứ nhất, học dựa trên histogram: thay vì duyệt toàn bộ dữ liệu, LightGBM phân nhóm các giá trị đặc trưng vào các bin histogram, giảm đáng kể bộ nhớ RAM và tăng tốc huấn luyện. Thứ hai, phát triển cây theo chiều lá: chọn lá có khả năng giảm sai số lớn nhất thay vì phát triển theo chiều sâu, giúp đạt độ chính xác cao hơn hoặc tương đương XGBoost trên cùng số lượng lá.

Lý do đưa LightGBM vào so sánh: Trong bối cảnh triển khai tiện ích mở rộng Chrome, kích thước file JSON của mô hình là yếu tố then chốt. LightGBM thường tạo ra file JSON nhỏ hơn XGBoost đáng kể do cơ chế histogram làm giảm số lượng điểm phân chia, giúp tăng tốc tải mô hình và giảm độ trễ suy luận phía client. Đây là ưu điểm trực tiếp phục vụ mục tiêu độ trễ dưới 200ms của đề tài.

2.5.5. Support Vector Machine và Decision Tree

Support Vector Machine tìm ra siêu phẳng tối ưu để phân tách hai lớp URL. Rất mạnh với ranh giới phi tuyến tính qua các hàm kernel RBF và Polynomial, nhưng tiêu tốn nhiều tài nguyên trên dữ liệu lớn và nhạy cảm với mất cân bằng lớp. Trong các nghiên cứu tham chiếu, SVM đạt độ chính xác từ 87,1% đến 95,8% nhưng có thể giảm xuống 72,2% khi dữ liệu mất cân bằng nghiêm trọng.

Decision Tree phân chia dữ liệu dựa trên tiêu chí tối đa hóa Information Gain hoặc giảm thiểu Gini Impurity. Dễ hiểu và dễ diễn giải nhưng dễ bị học vẹt khi không

cắt tía. Decision Tree trong đề tài đóng vai trò là mô hình đơn lẻ yếu nhất để làm nổi bật lợi thế của các phương pháp tập hợp. Đạt độ chính xác từ 85,3% đến 96,0% với tỷ lệ báo động giả cao nhất khoảng 5,8%.

2.6. Chỉ số đánh giá hiệu suất

2.6.1. Các chỉ số phân loại cơ bản

Accuracy hay độ chính xác tổng thể là tỷ lệ số mẫu được phân loại đúng trên tổng số mẫu, được tính theo công thức:

$$Accuracy = (TP + TN) / (TP + TN + FP + FN)$$

Tuy nhiên chỉ số này không đủ tin cậy khi dữ liệu mất cân bằng, vì một mô hình luôn dự đoán "an toàn" vẫn đạt Accuracy trên 95% nếu chỉ 5% mẫu là phishing.

Precision hay độ chụm đo lường trong số các URL bị đánh dấu là phishing, bao nhiêu thực sự là phishing:

$$Precision = TP / (TP + FP)$$

Precision cao đồng nghĩa với tỷ lệ báo động giả thấp, tức ít chặn nhầm trang hợp lệ, giảm phiền nhiễu cho người dùng.

Recall hay độ nhạy đo lường trong số tất cả các URL phishing thực sự, bao nhiêu được phát hiện:

$$Recall = TP / (TP + FN)$$

Recall cao đồng nghĩa với tỷ lệ bỏ sót thấp. Đây là chỉ số quan trọng nhất về mặt bảo mật.

F1-Score là trung bình điều hòa của Precision và Recall, giúp cân bằng giữa hai yêu cầu đối nghịch:

$$F1 = 2 \times (Precision \times Recall) / (Precision + Recall)$$

2.6.2. Chỉ số năng cao

ROC-AUC là diện tích dưới đường cong đặc trưng vận hành bộ thu, đánh giá khả năng phân loại tổng quát của mô hình ở mọi ngưỡng phân loại. Giá trị AUC bằng 1,0 là phân loại hoàn hảo; AUC bằng 0,5 tương đương đoán ngẫu nhiên. ROC-AUC đặc biệt hữu ích khi so sánh sức mạnh phân tách giữa các mô hình một cách công bằng.

MCC là hệ số tương quan Matthews, chỉ số mạnh nhất để đánh giá chất lượng phân loại trên tập dữ liệu mất cân bằng. MCC xem xét đồng thời cả bốn giá trị TP, TN, FP, FN để cho điểm số trong khoảng từ -1 đến +1. Giá trị MCC bằng +1 là phân loại hoàn hảo; MCC bằng 0 nghĩa là mô hình không tốt hơn đoán ngẫu nhiên. MCC đáng tin cậy hơn Accuracy và F1-Score khi tỷ lệ hai lớp chênh lệch lớn.

FPR và FNR là hai chỉ số bổ sung đánh giá chi phí của lỗi phân loại theo hai hướng. FPR đo tỷ lệ URL hợp lệ bị chặn nhầm, ảnh hưởng trực tiếp đến trải nghiệm người dùng:

$$FPR = FP / (FP + TN)$$

FNR đo tỷ lệ URL phishing bị bỏ sót, ảnh hưởng trực tiếp đến mức độ bảo mật:

$$FNR = FN / (FN + TP)$$

Mục tiêu của đề tài là tối thiểu hóa đồng thời cả FPR và FNR.

2.6.3. Chỉ số hiệu năng thực thi

Latency hay độ trễ suy luận là thời gian tính toán trung bình tính bằng millisecond để phân loại một URL, đo từ lúc nhận chuỗi URL đến lúc trả về kết quả. Đây là chỉ số quyết định khả năng triển khai thực tế: hệ thống phải hoàn thành suy luận trước khi trang web kịp tải trên trình duyệt. Mục tiêu của đề tài là độ trễ dưới 200ms. Việc xuất mô hình sang JSON và suy luận bằng JavaScript thuần phía client được kỳ vọng đạt mục tiêu này với biên độ an toàn.

Kích thước mô hình là kích thước file JSON ảnh hưởng đến thời gian tải tiện ích mở rộng lần đầu và bộ nhớ đệm chiếm dụng trong trình duyệt. Đây là lý do LightGBM được đưa vào so sánh bên cạnh XGBoost, vì trong nhiều trường hợp LightGBM tạo ra file nhỏ hơn với độ chính xác tương đương.

2.7. Kiến trúc triển khai Chrome Extension Manifest V3

2.7.1. Kiến trúc tiện ích mở rộng

Tiện ích mở rộng Chrome theo chuẩn Manifest V3 được thiết kế để đảm bảo an toàn, tối ưu hóa hiệu suất và hoạt động theo thời gian thực. Kiến trúc bao gồm ba thành phần chính:

1. Background Script hay Service Worker là thành phần cốt lõi hoạt động ngầm, có nhiệm vụ giám sát liên tục các sự kiện điều hướng web và quản lý logic phát hiện phishing. Trong Manifest V3, Background Page được thay thế bởi Service Worker để tiết kiệm tài nguyên hệ thống.
2. Content Script là tập lệnh được nhúng trực tiếp vào trang web người dùng đang truy cập, giúp tương tác với cấu trúc trang hoặc hiển thị các lớp phủ cảnh báo khi phát hiện nguy hiểm.
3. Popup là giao diện người dùng hiện ra khi nhấp vào biểu tượng tiện ích mở rộng, được xây dựng bằng HTML, CSS và JavaScript, cho phép người dùng theo dõi trạng thái an toàn của trang và xem nhật ký quét.

2.7.2. Quy trình xử lý và triển khai mô hình

Quy trình hoạt động của hệ thống diễn ra hoàn toàn tự động. Khi người dùng bắt đầu truy cập một trang web mới, Background Script đánh chặn sự kiện điều hướng và trích xuất ngay lập tức chuỗi URL. Script chạy các biểu thức chính quy và logic chuỗi để bóc tách tập hợp các đặc trưng ngữ vựng tĩnh có trọng số cao nhất gồm độ dài URL, số lượng tên miền phụ, tỷ lệ chữ số, sự hiện diện của địa chỉ IP và ký tự đặc biệt. Các đặc trưng vừa trích xuất được đóng gói thành vector dữ liệu để đưa vào mô hình phân loại.

Về triển khai mô hình: Mô hình được huấn luyện offline bằng Python với tập dữ liệu lớn. Sau khi huấn luyện hoàn tất, toàn bộ cấu trúc cây quyết định được lưu dưới định dạng file JSON nhỏ gọn và đóng gói trực tiếp bên trong file .crx của tiện ích mở rộng. Tại phía client, hệ thống sử dụng JavaScript thuần để đọc file JSON và thực hiện suy luận bằng các vòng lặp duyệt cây quyết định với logic IF-ELSE đơn giản, không cần tải thư viện học máy nặng nề.

Khi có kết quả suy luận, hệ thống hiển thị cảnh báo theo thời gian thực. Màu xanh lá cây biểu thị URL an toàn và màu đỏ báo động URL lừa đảo, kèm theo lý do cảnh báo cụ thể và tỷ lệ xác suất lừa đảo do mô hình tính toán.

TÀI LIỆU THAM KHẢO

- [1] Le Page, A., & Komisarczuk, P. (2014). An Analysis of Phishing Blacklists: Google Safe Browsing, OpenPhish, and PhishTank. Proceedings of the Australasian Information Security Conference.
- [2] Mohammad, R. M., Thabtah, F., & McCluskey, L. (2014). Predicting Phishing Websites based on Self-Structuring Neural Network. Neural Computing and Applications.
- [3] Sahingoz, O. K., et al. (2019). Machine learning based phishing detection from URLs. Expert Systems with Applications, 117, 345-357.
- [4] Zouina, M., & Outtaj, B. (2017). A novel lightweight URL phishing detection system using SVM and similarity index. Human-centric Computing and Information Sciences.
- [5] IBM Security. (2024). IBM X-Force Threat Intelligence Index 2024. IBM Corporation.
- [6] OpenPhish. (2024). OpenPhish – Phishing Intelligence. Truy cập tại: <https://openphish.com>
- [7] PhishTank. (2024). PhishTank – Join the fight against phishing. Truy cập tại: <https://www.phishtank.com>
- [8] Verma, R., et al. (2024). Phishing URL Detection Using Machine Learning: A Survey. IEEE Access.

báo cáo phishing

ORIGINALITY REPORT

5%	4%	4%	%
SIMILARITY INDEX	INTERNET SOURCES	PUBLICATIONS	STUDENT PAPERS

PRIMARY SOURCES

1	www.ctu.edu.vn Internet Source	3%
2	Ton Duc Thang University Publication	2%

Exclude quotes	On	Exclude matches	< 100 words
Exclude bibliography	On		